Virtual Ink Security Architecture and Flow

Security boundaries for a web-first marketplace that can scale to Android and iOS

Document detail	Value
Prepared for	Shadow Root Security Technologies
Product	Virtual Ink - Your Ideas. Our Print. Delivered.
Current delivery model	Web-first, API-centred, mobile-ready
First outcome	A server-owned security model with tenant isolation, private files, auditable actions, and shared web/mobile API boundaries
Scope status	Architecture scope - not yet a production security certification
Revision	8 October 2026

How to use this document

This document is a build and review baseline. It separates confirmed foundation work from later marketplace, payment, delivery, and mobile work. Every sensitive feature must pass its acceptance gate before it is promoted.

1. Security objective

Virtual Ink must be safe for customers, vendors, operators, delivery partners, and future payment providers. The web application remains the first source of truth. Android and iOS clients will consume the same server API and must not duplicate authorization or pricing logic.

- Customer files, proofs, contact data, and order records are private by default.
- Vendor data is isolated by server-derived tenant scope.
- Prices, order totals, roles, and permissions are never trusted from the client.
- Important actions create durable audit events.
- Secrets, database credentials, storage keys, and signed URLs remain server-side.
- Manual operational steps are recorded honestly before automation is introduced.

2. Logical security architecture

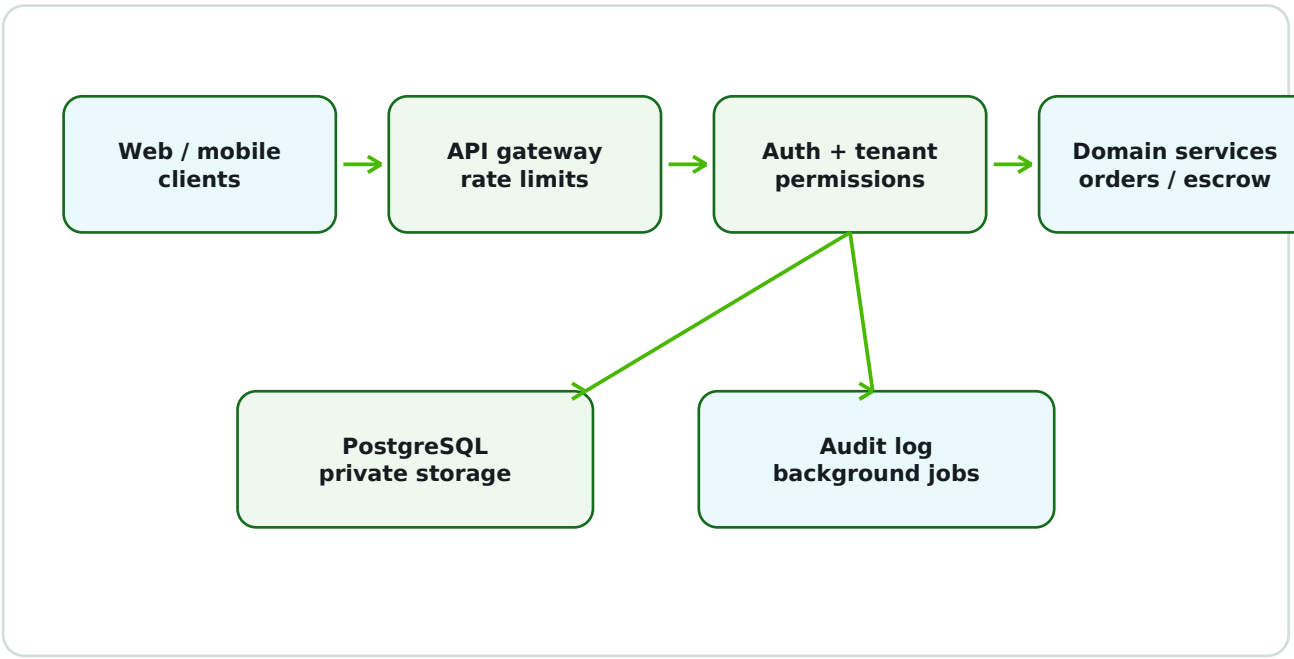


Figure 1. Clients reach the domain through the Virtual Ink API. The API verifies identity, tenant scope, resource ownership, and workflow state before changing data.

Trust boundaries

Zone	Responsibility	Required control
Client	Web, Android, and iOS interfaces	No secrets; no trusted totals; safe error display
API boundary	Authentication, validation, authorization and rate limits	Fail closed; structured errors; request IDs
Domain layer	Orders, quotes, escrow, vendor and delivery rules	Server-side state machine and ownership checks
Data layer	PostgreSQL and private object storage	Encryption, restricted credentials, retention and access logs
Workers	Quarantine scans, notifications and future jobs	Scoped service identity and idempotent jobs

3. Request security flow

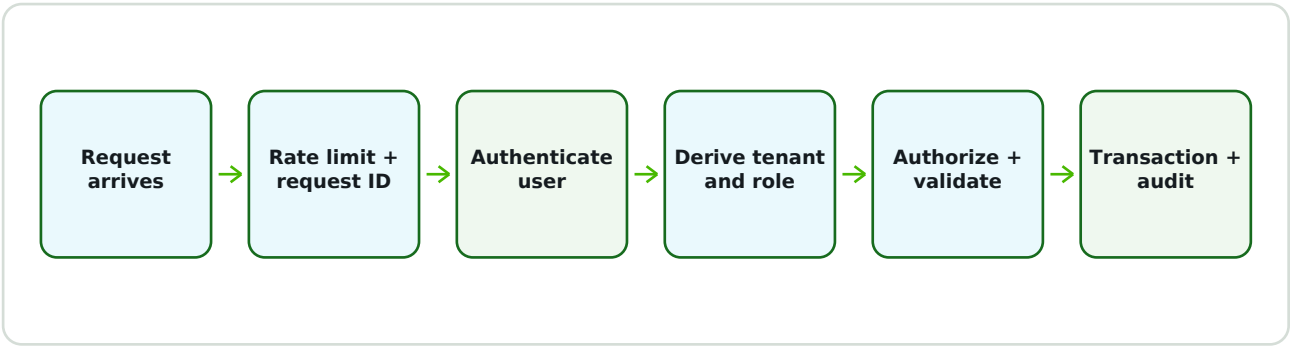


Figure 2. Every sensitive request follows the same server-owned flow. A failure at any stage returns a safe error and does not partially change the system.

- The server derives tenant and membership context from the authenticated session.
- Resource ownership is checked again inside the transaction where appropriate.
- Audit recording is fail closed for actions that require durable evidence.
- Responses reveal only data the caller is allowed to see.

4. Identity, roles and tenant isolation

Role	Permitted scope	Explicit exclusion
Customer	Own profile, files, quotes and orders	Other customers and vendor operations
Vendor owner	Own vendor workspace and assigned orders	Other vendors and platform administration
Vendor staff	Assigned vendor tasks only	Role management and financial overrides
Platform operator	Approved operational and reconciliation records	Unnecessary raw files and unrestricted technical access
Delivery partner	Assigned handover and delivery fields	Print files, proofs and payment details
Technical administrator	System maintenance with elevated audit	Unreviewed business approvals

Isolation rules

- Application-owned records carry vendor or tenant ownership where relevant.
- Queries apply ownership predicates on the server, not only in the UI.
- Negative tests prove guessed IDs, inactive memberships, wrong roles, and cross-tenant access are denied.
- Supabase Auth, Storage, and PostgreSQL are accessed through reviewed server adapters.

5. Data, files and audit protection

Data type	Protection policy
Customer files and proofs	Private storage; scoped access; quarantine before processing; retention and deletion rules
Payment records	Provider references and verification records only; no unnecessary card data
Audit events	Append-only operational record; restricted visibility; no secrets or file contents
Sessions and secrets	Protected cookies or secure token storage; environment secret management
Operational exports	Least privilege, explicit purpose, expiry and access logging

6. Threat and control register

Threat	Primary control	Proof
Cross-vendor data leak	Server-derived tenant scope and ownership checks	Isolation denial tests
Price tampering	Server-side quote calculation and accepted snapshot	Tamper test
Malicious upload	Type/size validation, quarantine and malware scan	Rejected-file tests
Account takeover	Session revocation, rate limits and operator MFA path	Auth and abuse tests
Insider misuse	Least privilege, audit events and support access records	Audit review
Webhook replay	Idempotency keys and provider event ledger	Replay test

7. Web-first scaling model

The web platform remains the reference client while Virtual Ink expands to mobile. Business rules stay in the API so web, Android, and iOS receive the same authorization, quote, escrow, and order behavior.

Layer	Web now	Android and iOS later
Interface	Next.js App Router source shell	React Native or Expo client using the same API
Business rules	Virtual Ink server API	No duplicated pricing or permission logic
Identity	Server-managed sessions	Secure mobile session storage and deep links
Files	Private upload contract when approved	Mobile uses scoped upload sessions, never storage keys
Release	Private web preview and controlled environments	Android internal testing and iOS TestFlight before store release

8. Security build gates

Gate	Must be true before moving on
Gate 1 - Identity	Roles, memberships and session behavior are documented and tested.
Gate 2 - Tenant isolation	Cross-tenant reads and writes are denied by server tests.
Gate 3 - Audit	Sensitive actions create durable audit records.
Gate 4 - Escrow	Ledger and state transitions are tested without live money movement.
Gate 5 - Mobile	Mobile clients use API contracts, secure sessions, and no privileged keys.
Gate 6 - Store	Privacy, account deletion, release signing, testing and incident plans are ready.

9. Immediate security actions

- Uchi accepts the Phase 2 permission matrix and unresolved security decisions.
- Mumba creates application-owned users, tenants, memberships, and audit tables.
- Mumba proves denial for unauthenticated, inactive, wrong-role, guessed-ID, and cross-tenant requests.
- Taizya documents secure UI states for login, access denied, payment pending, dispute, and account deletion.
- Lubasi confirms support access, delivery visibility, payment verification, refund and dispute procedures.